



FFIEC Information Technology Examination Handbook

Development, Acquisition, and Maintenance

AUGUST 2024

INTRODUCTION	1
I..... OVERVIEW OF DEVELOPMENT, ACQUISITION, AND MAINTENANCE	3
II..... GOVERNANCE OF DEVELOPMENT, ACQUISITION, AND MAINTENANCE	5
II.A Policies, Standards, and Procedures	6
II.B Roles and Responsibilities.....	6
II.B.1 Board, Senior Management, and Other Common Roles.....	7
II.B.2 IT Project Management Roles.....	8
II.B.3 Development Roles.....	10
II.B.4 Acquisition Roles.....	12
II.B.5 Maintenance Roles	14
II.B.6 Other Common Development, Acquisition, and Maintenance Roles.....	14
II.B.7 Supply Chain Roles.....	15
II.B.8 Other Support Functions	15
II.B.9 Audit's Role	16
III..... RISK MANAGEMENT OF DEVELOPMENT, ACQUISITION, AND MAINTENANCE.....	18
III.A Risk Identification	19
III.B Risk Measurement	20
III.C Risk Monitoring and Reporting	20
III.D Controlling or Mitigating Risk	21
IV..... COMMON DEVELOPMENT, ACQUISITION, AND MAINTENANCE RISK TOPICS.....	22
IV.A Open-Source.....	23
IV.B Commercial-off-the-Shelf	25
IV.C Licenses, Agreements, and Copyright Protection	26
IV.C.1 Software Licenses.....	27
IV.C.1(a) Free and Open-Source Software Licenses	28
IV.C.1(b) Proprietary Software Licenses	28
IV.C.2 Hardware Licenses	29
IV.C.3 Copyright Protection.....	29
IV.D Secure Development.....	30

IV.E	Data	32
IV.F	Secure Operating Environments	32
IV.G	Microservices	33
IV.H	Containers	37
IV.I	Application Programming Interfaces	43
IV.I.1	API Gateway	44
IV.I.2	API Risk Mitigation	46
IV.J	Methodologies	48
IV.J.1	Waterfall	49
IV.J.2	Agile	49
IV.K	Quality Management	52
IV.L	Documentation Standards	53
IV.M	Post-Implementation Review	54
IV.N	IT Project Management	55
IV.N.1	IT Project Phases	56
IV.N.1(a)	<i>Initiation</i>	<i>57</i>
IV.N.1(b)	<i>Planning</i>	<i>58</i>
IV.N.1(c)	<i>Execution</i>	<i>59</i>
IV.N.1(d)	<i>Closeout</i>	<i>59</i>
IV.N.2	Monitoring and Controlling	60
IV.N.3	IT Project Documentation	61
IV.N.3(a)	<i>IT Project Request</i>	<i>61</i>
IV.N.3(b)	<i>Business Case</i>	<i>62</i>
IV.N.3(c)	<i>Feasibility Study</i>	<i>62</i>
IV.N.3(d)	<i>IT Project Plans</i>	<i>63</i>
IV.N.3(e)	<i>Closeout Documentation</i>	<i>63</i>
IV.O	System Development Life Cycle	64
IV.O.1	SDLC Phases	65
IV.O.1(a)	<i>Initiation</i>	<i>66</i>
IV.O.1(b)	<i>Development or Acquisition</i>	<i>68</i>
IV.O.1(c)	<i>Implementation and Assessment</i>	<i>69</i>
IV.O.1(d)	<i>Operations and Maintenance</i>	<i>71</i>
IV.O.1(e)	<i>Sunset and Disposal</i>	<i>72</i>
IV.P	Third-Party Relationship Risk Management	74
IV.P.1	Planning	74

IV.P.2	Due Diligence and Third-Party Selection	74
IV.P.3	Contract Negotiation	75
IV.Q	Supply Chain Considerations	75
IV.Q.1	Supply Chain Risk Management.....	77
IV.Q.2	Software Bill of Material	89
IV.Q.3	Enterprise Risk Management and Supply Chain Risks	90
V	DEVELOPMENT	91
V.A	Development Standards and Controls	93
V.B	Testing	96
V.C	DevOps and DevSecOps	99
V.C.1	DevOps	100
V.C.2	DevSecOps.....	100
V.D	Functional Development Types	105
V.D.1	Model Development	106
V.D.2	Database Development.....	107
VI	ACQUISITION.....	109
VI.A	Acquisition Policies, Standards, and Procedures.....	111
VI.B	Acquisition Projects	113
VI.C	Solicitation.....	113
VI.D	Evaluation.....	116
VI.E	Contracts and Other Agreements.....	117
VI.E.1	Statement of Work	117
VI.E.2	Master Services Agreement.....	119
VI.E.3	Service Level Agreement.....	120
VI.E.4	Contracts.....	120
VI.E.5	Escrowed Source Code Agreements and Documentation	124
VI.E.6	Exit Strategy.....	125
VII	MAINTENANCE.....	126
VII.A	Preventive Maintenance	127
VII.B	Change Management	127
VII.B.1	Implementing Changes	129
VII.B.2	Additional Control Considerations in Change Management.....	132
VII.B.2(a)	<i>Data Controls in the Testing Environment.....</i>	<i>132</i>
VII.B.2(b)	<i>Library Controls.....</i>	<i>132</i>

VII.B.2(c)	<i>Code Repository Controls</i>	133
VII.B.3	<i>Change Types</i>	135
VII.B.3(a)	<i>Routine Modifications</i>	135
VII.B.3(b)	<i>Major Modifications</i>	136
VII.B.3(c)	<i>Emergency Modifications</i>	137
VII.B.4	<i>Change Management Documentation</i>	139
VII.B.4(a)	<i>Change Request Form</i>	140
VII.B.4(b)	<i>Impact Analysis</i>	140
VII.B.4(c)	<i>Rollback or Back-Out Plan</i>	141
VII.C	End-of-Life	142
VII.D	Termination and Disposal	144
VII.E	Maintenance Documentation	145
APPENDIX A: EXAMINATION PROCEDURES		146
APPENDIX B: GLOSSARY		182
APPENDIX C: ABBREVIATIONS		202
APPENDIX D: REFERENCES		204

INTRODUCTION

The “Development, Acquisition, and Maintenance” booklet is one in a series of booklets that compose the *Federal Financial Institutions Examination Council (FFIEC)*¹ *Information Technology Examination Handbook (IT Handbook)*. The *FFIEC IT Handbook* is prepared for use by examiners.² With the publication of this booklet, the FFIEC members replace the “Development and Acquisition” booklet issued in April 2004. The revised title now reflects the importance of maintenance in the life of a system or component.³ This booklet

- Describes system and component development, acquisition, and maintenance.
- Highlights key risk management practices when developing, acquiring, or maintaining systems and components.
- Provides an overview of and discusses information technology (IT) project management, the system development life cycle (SDLC), and supply chain risk management (SCRM).
- Addresses the importance of system and software maintenance to an entity’s resilience.

For *FFIEC IT Handbook* purposes, the term “entity” includes depository financial institutions,⁴ nonbank financial institutions,⁵ bank holding companies,⁶ savings and loan holding companies,⁷ and third-party service providers.⁸

¹ The FFIEC was established on March 10, 1979, pursuant to [Title X of the Financial Institutions Regulatory and Interest Rate Control Act of 1978, Pub. L. 95-630](#). The FFIEC comprises the principals of the Board of Governors of the Federal Reserve System (FRB), the Consumer Financial Protection Bureau (CFPB), the Federal Deposit Insurance Corporation (FDIC), the National Credit Union Administration (NCUA), the Office of the Comptroller of the Currency (OCC), and the State Liaison Committee (SLC).

² Each FFIEC member uses the principles outlined in this booklet consistent with the member’s supervisory authority.

³ Examples of systems and components include hardware, firmware, software, peripherals, and network components.

⁴ The term “depository financial institution” includes national banks, federal savings associations, state savings associations, state member banks, state nonmember banks, and credit unions.

⁵ The term “nonbank financial institution” includes nondepository financial institutions under the jurisdiction of either state banking departments or the CFPB.

⁶ The term “bank holding company” includes any company that has control over any bank or over any company that is or becomes a bank holding company as defined by the [Bank Holding Company Act](#).

⁷ The term “savings and loan holding company” includes any company that directly or indirectly controls a savings association or controls any other company that is a savings and loan holding company as defined by the [Home Owners’ Loan Act](#).

⁸ The term “third-party service provider” means third parties that provide services, the provision of which is subject to examination under the [Bank Service Company Act](#), the [Home Owners’ Loan Act](#), the [Dodd–Frank Wall Street Reform and Consumer Protection Act](#), or other relevant law.

This booklet does not impose new requirements on entities. Instead, this booklet describes the principles and practices that examiners can use when assessing an entity's system development, acquisition, and maintenance activities.

[Appendix A](#) of this booklet provides objectives-based examination procedures. Application of principles and related examination procedures will vary consistent with the examined entity's complexity and risk profile (including the size of the entity or the nature of the systems and components).

I OVERVIEW OF DEVELOPMENT, ACQUISITION, AND MAINTENANCE

Development, acquisition, and maintenance activities are integral to an entity's operations. This booklet discusses how weaknesses in IT development, acquisition, and maintenance processes may lead to issues with confidentiality, integrity, availability, and resilience of the entity's systems, components, and data. Management determines the systems, products, and services that the entity will provide, whether to develop or acquire them, and how to maintain and service those systems, products, and services. Generally, whether developing or acquiring systems, products, and services, management performs some form of acquisition activity, including procurement. Management also oversees maintenance activities to prolong the life of systems and components (i.e., IT assets) and support continuity of operations. Management should plan for maintenance activities from the outset of acquisition or development to ensure secure continuity of operations. The following definitions and explanations provide an overview of IT development, acquisition, and maintenance.

Development: Systematic application of knowledge toward the production of useful materials, devices, and systems, or processes of defining, designing, testing, and implementing systems or components. Development includes validation and demonstration of a chosen technology, use of test and production environments, improvement of developed prototypes, integration into systems and subsystems, and inclusion of hardware builds. Development activities may be performed by the entity's personnel or third parties who develop systems and components on the entity's behalf. Management may choose to acquire systems and components from third parties and may customize them to meet the entity's needs.

Acquisition: All stages for acquiring products or services, beginning with determining the need for the product or service and ending with contract completion and closeout. Acquisition generally involves creating a relationship with a third party in the supply chain; therefore, effective SCRM is integral to the acquisition process. Acquisition activities include procurement processes that help ensure that management receives the contracted products or services. Acquisition activities, including procurement processes, help management achieve and maintain confidentiality, integrity, availability, as well as resilience, including supply chain resilience, throughout the life of systems and components.

Maintenance: Any act that either prevents the failure or malfunction of equipment or restores its operating capability. This includes incremental changes to improve performance. Maintenance activities include the processes to monitor systems and components and make changes (e.g., install patches and add new functions) to prevent their failure or malfunction and continue to meet user and customer needs. Management should perform preventive maintenance throughout the IT asset's useful life to prevent or minimize catastrophic failure and promote confidentiality, integrity, availability, and resilience. Maintenance may be performed by the entity's personnel or third parties. Maintenance activities should be performed regardless of the origin or location (e.g., geographic or virtual) of the systems or components.

The next section of this booklet addresses governance and risk management elements. Also addressed are common risk topics related to development, acquisition, and maintenance. The

booklet explains key topics, such as IT project management, SDLC, and supply chain risk management considerations, which are integral to development, acquisition, and maintenance activities to provide for ongoing operations. Appendices provide examination procedures, agency and industry references, and a glossary.

II GOVERNANCE OF DEVELOPMENT, ACQUISITION, AND MAINTENANCE

Action Summary

Management should establish, and the board of directors (board) should oversee, an effective governance framework for development, acquisition, and maintenance activities. Additionally, the board should oversee related IT project management processes to manage projects related to those activities.

Examiners should review the following:

- Enterprise-wide IT policies, procedures, and standards describing the entity's requirements throughout the development, acquisition, and maintenance life cycle.
- Charters (e.g., board, management, or committee), organizational charts, relevant documentation, and practices to determine whether appropriate roles and responsibilities are identified and assigned with suitable decision-making authority.
- Project plans and meeting minutes of the board and committees to ensure that activities and projects align with the entity's strategic objectives and the board's risk appetite.
- Project audit reports to determine whether the audit function provides independent, objective assurance of the effectiveness of an entity's development, acquisition, and maintenance activities.
- Documentation of controls for personnel with access to program code to limit placement into the production environment.
- Quality assurance (QA) reports to evaluate processes for the detection of potential coding errors.

The board⁹ should oversee and management should establish an effective governance structure that allows for the effective oversight and management of the development, acquisition, and maintenance of the entity's systems and components. Additionally, the board should oversee related IT project management processes and projects related to those activities. The board should oversee significant projects to ensure that they align with an entity's strategic plans. Projects that do not align may cause lost revenue or diminished economies of scale resulting in budget shortfalls. Misalignment may cause unexpected harm to the entity or its reputation (e.g., customer dissatisfaction, user frustration, noncompliance with laws and regulations, and IT or operational performance issues). Ineffective communication or coordination by the board with appropriate stakeholders can lead to problems (e.g., scope creep on projects and cost overruns) and processes that do not facilitate appropriate communication across business departments. When IT activities are siloed away from business departments or other business line IT departments (i.e., when an entity has multiple lines of business that have their own IT departments), it may result in management establishing counterproductive objectives.

⁹ Most financial institutions have boards; however, not all third-party service providers do. When an entity does not have a board, senior leaders may have the responsibilities of a board as described in this booklet.